

Forensic Response Plan: Yorkuni Leisure Group (YULG)

Pre-incident preparation

The steps that will be listed below are in line with ISO standards and best practices.

1. Prepare the relevant documentation and policies

- Incident response management policy: this provides principles and intentions for direct decision making. It outlines responsible persons, processes, as well as reporting lines for an information security incident.
- Incident management Plan: The aim of an information security incident plan is to document and disseminate the processes and procedures for handling information security incidents, events, and related vulnerabilities that are identified during incident response and analysis [1]. Some of the following documents make up a plan:
 - i. Categorization of information security incidents: ISO 27035 provides an annex detailing examples of information security events which are categorized according to threats. ISO 27005 explains what threats are [2].
 - ii. Incident forms are important for capturing information about incidents. This should be done and approved by an Incident Management Team (IMT) before incident occurs. See Annex B of ISO 27035 [1].
 - iii. Documented processes and procedures: A list of incidents that the organization wants to be able to manage should be established and maintained. Operating procedures for the IMT and Incident Response Team (IRT) should also be documented.
- Standard Operation procedure for common operations and key tasks. See ISO 27042 [3].

2. Create Appropriate teams

a. Incident Management Team

This comprises a group of people responsible for managing the incident management capability of an organization, end to end [1]. It could include roles like the Incident Manager, Planning team, monitoring team, Analysis team and Evaluation team. The Incident management policy and plan outlined above should be built and managed by the Incident manager. See ISO 27035 for roles and responsibilities of the IMT.

b. Incident Response Team

This team is functions to respond to an incident and is disbanded after remediation is completed. They could be structured in different ways and have different personnel providing expertise, both internal and external. It is led by an Incident Coordinator. See ISO 27035 for roles and responsibilities of the IRT.

3. **Implement adequate technical measures**

This involves a number of checks and implementations. But will be tailored to a small company with servers, PCs, directories and basic network security.

- Assess the security level using information security audit mechanism
- Regularly patch machines with security updates as vulnerability management
- Take backups regularly and test that they work. The Central server and network devices being the focus here.
- Ensure comprehensive logging practice for:
 - o Router- Network traffic logs
 - o Windows laptops- Windows event logs for offline login
 - o Central Server and web server- storage access logs (file and databases too), directory system log for online user access
 - o Firewall- firewall logs

These logs can then be provided for audit purposes and monitoring

- Access control and efficient identification and authentication measures
- **Seeing as there was a malware outbreak incident**, it is imperative to ensure protection of Endpoint devices by installing anti-malware software and intrusion detection and prevention systems on Servers and network devices. Disable use of external USB drives and installing of applications, or where necessary, let it prompt for elevated privilege by an IT admin
- Continuous training for staff and system users on IT security awareness.

4. **Stock on forensic tools and software for evidence gathering, preservation and Analysis**

It goes without saying that these plans and technical measures must be tested to be sure they work, e.g server backups.

In the event of another incident however, the pre-incident steps listed above would not be enough to tackle it. We would need an Incident response approach highlighting actions to take so as to maximize the potential digital evidence available for further investigation.

Immediate Incident response

Upon suspicion of a security incident, the framework or approach provided below should be used immediately. The scope of this response framework applies to Yorkuni Leisure Group as its devices fall under the scope of devices provided in ISO 27037 [4].

I. **Initial response and Containment.**

This stage is important as it enables us maximize the potential evidence that we can gather and also prevent more damage to business. They include actions like:

Documentation and assessment: Ensure to assess the scope of the incident that has just occurred as well as its perceived impact, making sure to document your initial observations such as devices and components present, time of detection, time of entering the scene.

Containment: Isolate infected devices to prevent further damage to the network or business. If there are compromised accounts, shut them down. Seal off the area to prevent tampering of potential evidence ensuring that you give a reasonable locus around the crime scene. It is easier to work your way inwards thereafter, than outwards. **This must be done in a way to ensure Auditability, Justifiability, and repeatability (or reproducibility depending on context and situation)**

II. Identification

This process involves the search, recognition and documentation of potential digital evidence (PDE) which could be in physical or logical. Use asset register to identify devices, data sources that could hold PDE. This could be storage media or processing device. Take note of Volatility of data to ensure prioritization. Note that sources of potential evidence can go beyond just digital media and could be disguised or co-mingled amongst irrelevant material.

III. Collection

Collection is a process of removing devices that may contain PDE from their original location to a controlled environment for acquisition if required, and analysis [4]. The devices may be in on or off state, materials relating to them like power connectors, cradles, paper with passwords must be collected as well. The entire process and devices collected must be documented.

- Take note of Type, markings, serial numbers, anything connected, attached or inserted. Use photographs as much as possible.
- Collect network traffic logs where network devices are involved
- Collaborate with cloud providers to obtain logs and data for the cloud server.
- Prioritize volatile data like in RAM, or running processes.

Please note: Collection is the gold standard, but as is the case in YULG where **Users take systems out of the office for use at home**, proceed to **Acquisition** and ensure the following:

- Obtain physical image of disks or drives, obtain logical copy if source is too large.
- Use write-blockers and forensic tools for imaging. See ISO 27041 for guidance [5].
- Verify Equivalence by computing hashes or any other method considered appropriate.
- Document every action taken from start to finish including chain of custody.

IV. Preservation of Potential Digital Evidence

Preserve PDE to ensure its usefulness and integrity for investigation and must be maintained throughout digital handling process right from identification of potential digital evidence [4]. Any action that might result in spoilation or alteration of PDE must be avoided. Collected evidence must be stored in a secure, access-controlled location. Some best practices are:

- Use write-once media where possible
- Work on copies of the original image

- Preserve PDE for as long as investigation is ongoing. Discard when local jurisdiction and legal requirement permits.

After all this is done, you can proceed to carrying out analysis on the PDE collected. The approach described above will ensure that there is a good amount of PDE available to carry on further investigation.

Possible area of conflict

In the incident response plan given above, it is possible for conflict to arise regarding containing the incident as this might require shutting off the network or disconnecting systems to prevent propagation. This can interfere with:

- a) collection of data- e.g volatile data in RAM or background processes
- b) continued operation of the business. (business disruption)

The IMT or IRT leader must consider the following criteria in resolving this:

1. Criticality of the evidence and the possibility of it being lost or spoiled if containment actions are taken.
2. The severity of potential impact on business operations as this is most important to management/directors.
3. What has been agreed in terms of allowed downtime to ensure there is no breach of SLA.
4. Legal and Regulatory requirements should be considered when deciding.

There could also be conflict in acquisition stage- imaging a user's device to be specific and how it might interrupt business operations. The IMT or IRT leader must consider the potential for ongoing data loss and severity of the incident. Prioritizing evidence collection from an affected files server might be more critical than from a receptionist system running offline.

References

- [1] B. I. 27035-2:2023, "Information technology — Information security incident management — Part 2: Guidelines to plan and prepare for incident response," BSI Standards Publication, 2023.
- [2] I. 27005:2022, " Information security risk management," BSI Standards Publication, 2022.
- [3] I. 27042:2015, "Information technology — Security techniques — Guidelines for the analysis and interpretation of digital evidence," BSI Standards Publication, 2015.
- [4] I. 27037:2012, "Information technology- Security Guidelines for identification, collection, acquisition and preservation of digital evidence," BSI Standards Publication, 2012.
- [5] I. 27041:2015, "Information technology - Security techniques - Guidance on assuring suitability and adequacy of incident investigative method," BSI Standards Publication, 2015.

